Network Security

CS 448/548

Lecture 21 – Final Exam Review

Spring 2026

Dr. Lina Pu

Final Exam

- Time: May 2, 8am-10am
- Closed book
- True or False
- Multiple Choice/Answers
- Short Answer
- Challenge Question
- Type of questions are similar to Midterm exams.
- Number of questions in each category will be different
- More questions due to extended exam duration time.

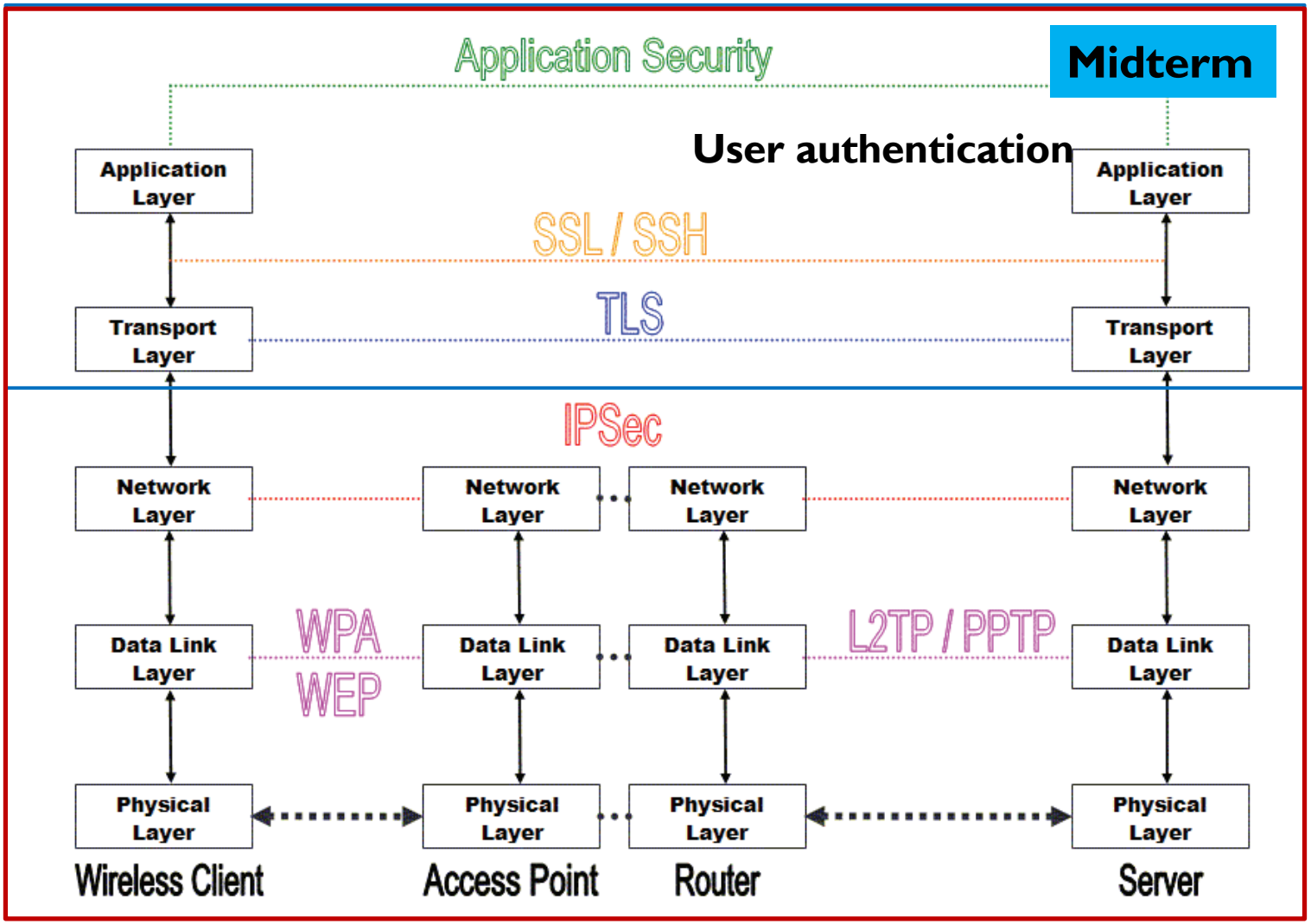
Example Questions

- 2022 Exam and Solutions Available on Blackboard/Slides and Videos folder
- 2025 Midterm Exam
  - Final will be comprehensive.

Topics Covered in Midterm

- Basic Cryptography
  - Symmetric cipher
  - Asymmetric cipher
  - Secure hash
- TLS
- User authentication
  - Kerberos
  - Oauth+OpenID Connect
- Refer to Lec 15 exam review

Layered Architecture of TCP/IP Model



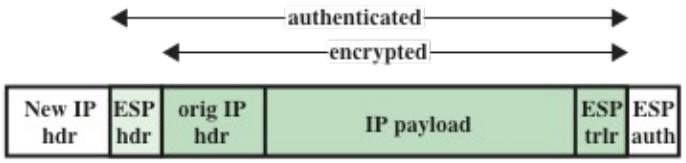
Final

IP Security

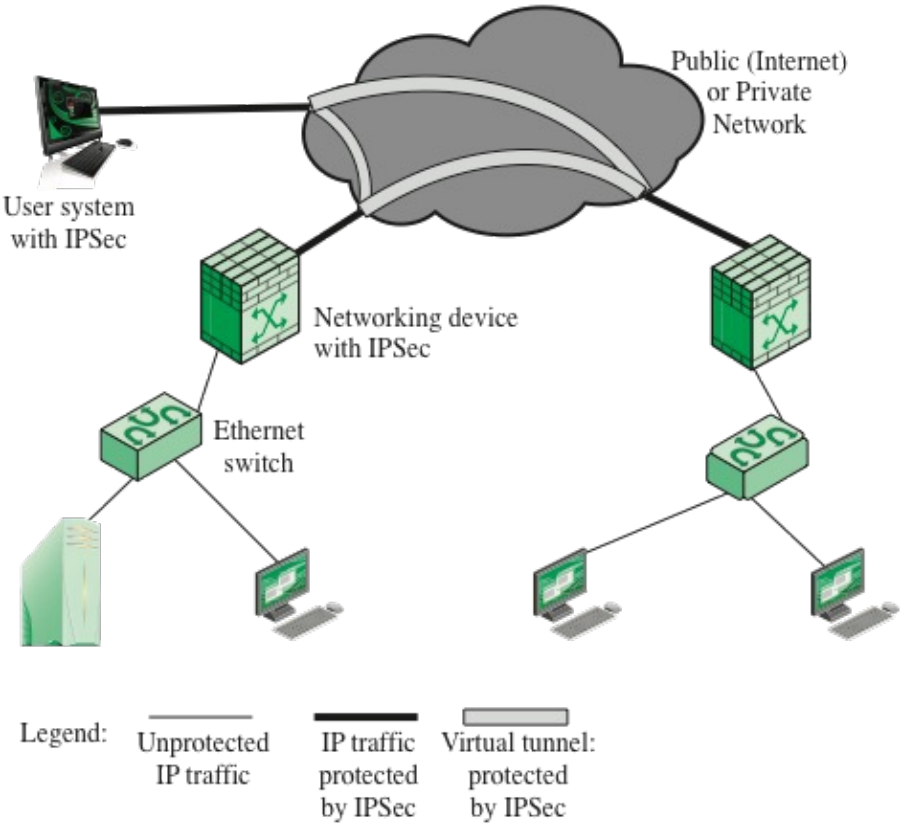
- IPSec provides
  - Access control: User authentication
  - Data integrity
  - Data origin authentication
  - Rejection of replayed packets
  - Confidentiality (encryption)
  - Limited traffic flow confidentiality
- Benefits:
  - Security at Layer 3 ⇒ Applies to all transports/applications
  - Can be implemented in Firewall/router
    ⇒ Security to all traffic crossing the perimeter
  - Transparent to applications and can be transparent to end users
  - Can provide security for individual users

IP Security Benefits

- IPsec can assure that:
  - A router advertisement comes from an authorized router
  - A router seeking to establish or maintain a neighbor relationship with a router in another routing domain is an authorized router
  - A redirect message comes from the router to which the initial IP packet was sent
  - A routing update is not forged



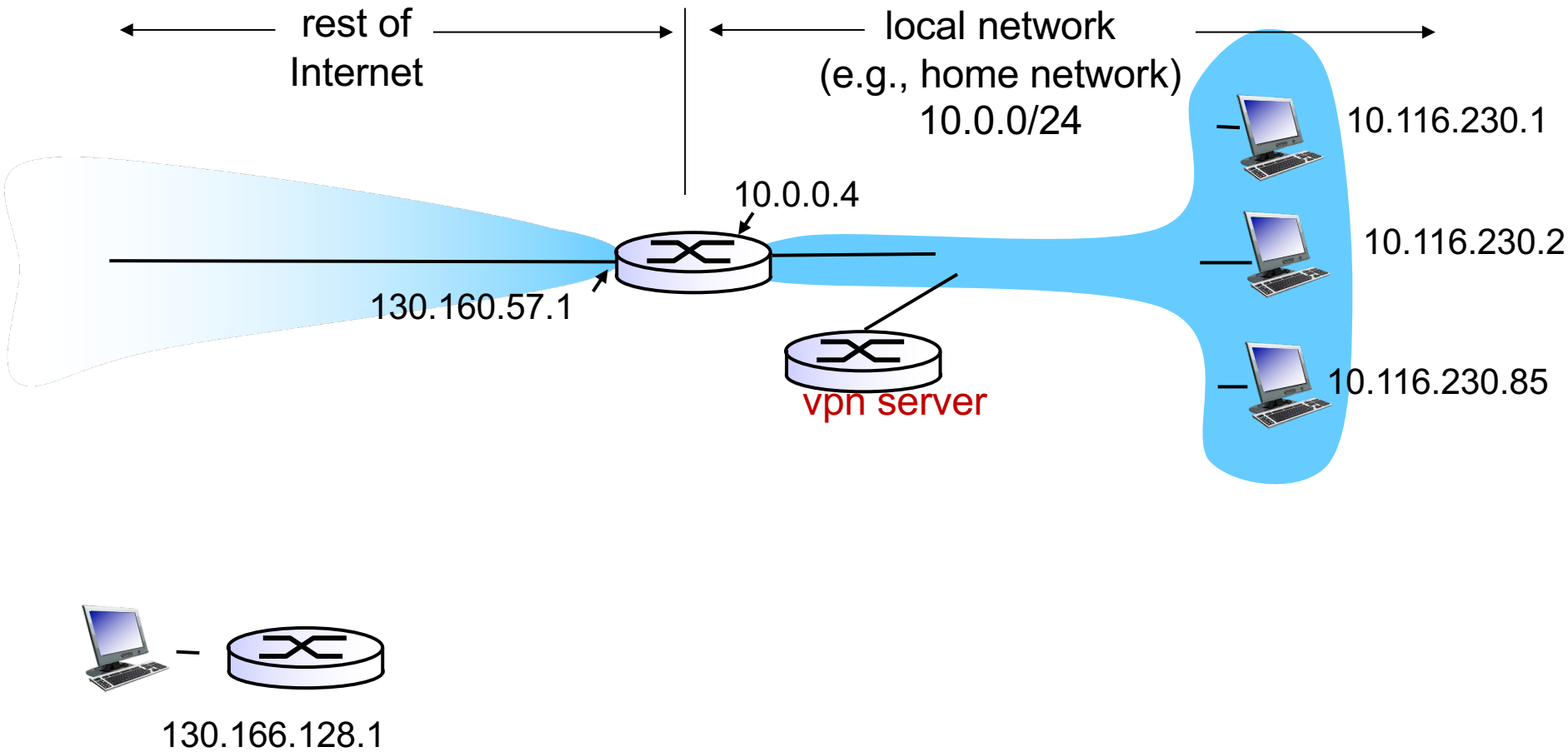
(a) Tunnel-mode format



(b) Example configuration

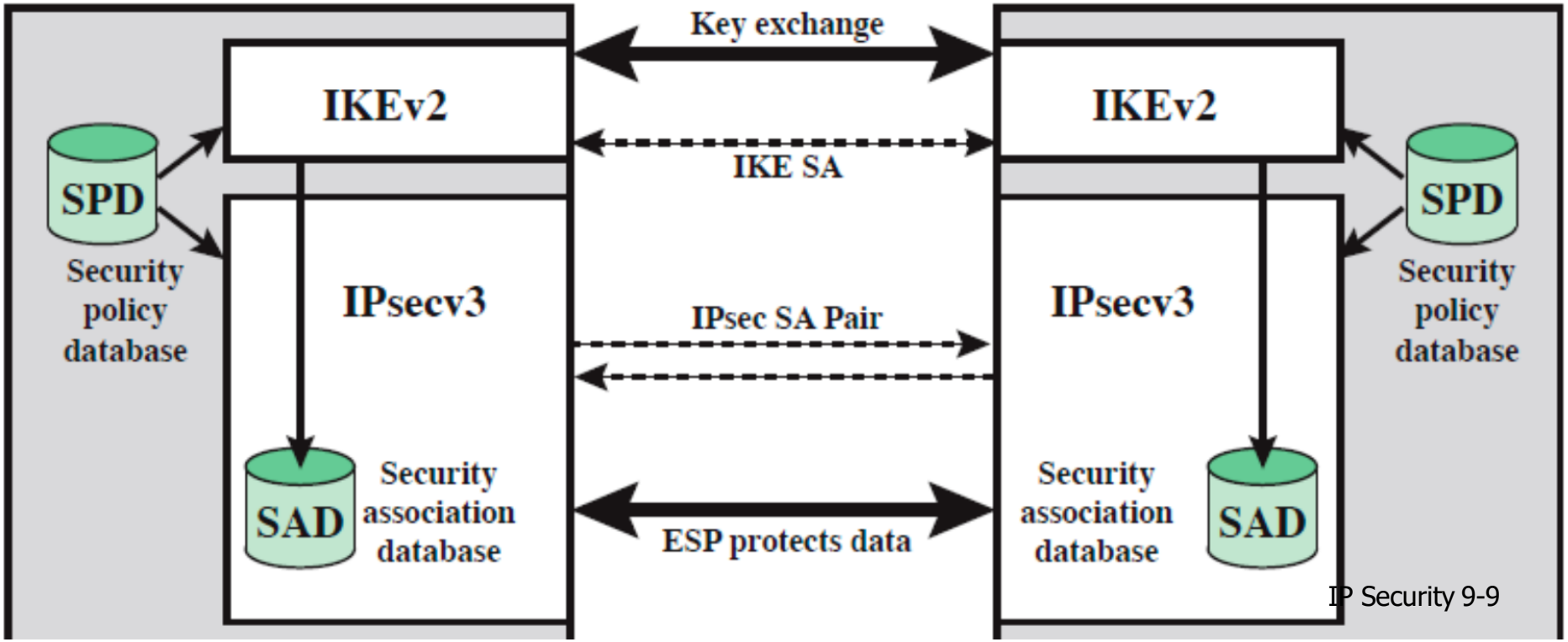
- Applications: VPNs, Branch Offices, Remote Users, Extranets

VPN


rest of
Internet
local network
(e.g., home network)
10.0.0/24
10.116.230.1
10.0.0.4
10.116.230.2
130.160.57.1
vpn server
10.116.230.85
130.166.128.1

IP Security Architecture

- Internet Key Exchange (IKE)
- Security Association Database
- Security Policy database
- IP Encapsulating Security Payload (ESP) and AH



Security Policy Database

- how to process different datagrams received by the device
  - Match subset of IP traffic to relevant SA
  - Use selectors to filter outgoing traffic to map
  - Based on: local & remote IP addresses, next layer protocol, name, local & remote ports

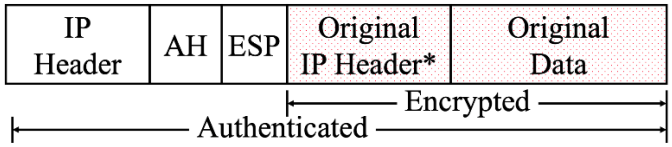
Protocol	Local IP	Port	Remote IP	Port	Action	Comment
UDP	1.2.3.101	500	*	500	BYPASS	IKE
ping ICMP	1.2.3.101	*	*	*	BYPASS	Error messages
*	1.2.3.101	*	1.2.3.0/24	*	PROTECT: ESP intransport-mode	Encrypt intranet traffic
TCP	1.2.3.101	*	1.2.4.10	80	PROTECT: ESP intransport-mode	Encrypt to server
TCP	1.2.3.101	*	1.2.4.10	443	BYPASS	TLS: avoid double encryption
*	1.2.3.101	*	1.2.4.0/24	*	DISCARD	Others in DMZ
*	1.2.3.101	*	*	*	BYPASS	Internet

Security Association Database

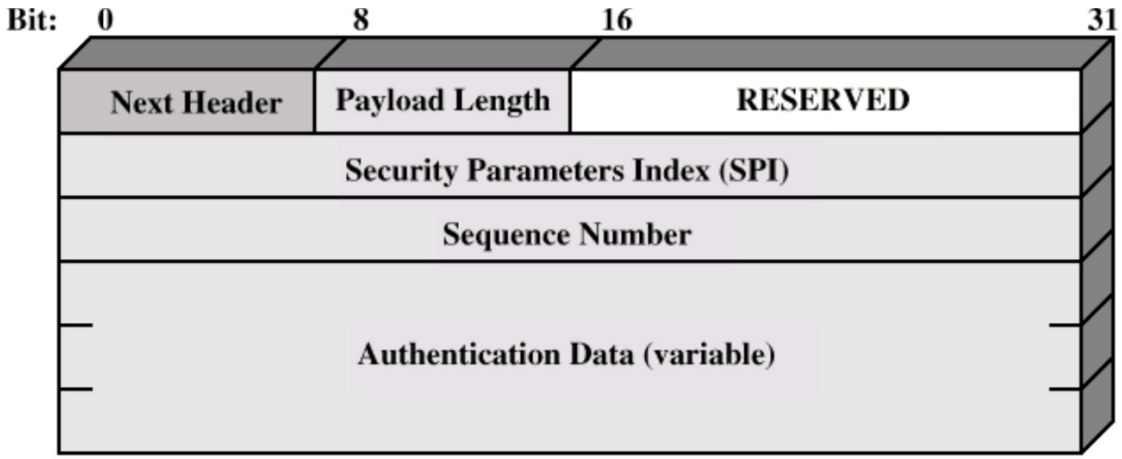
- Describes a particular kind of secure connection between one device and another
- Each host has a database of Security Associations (SAs)
- SA = One-way security relationship between sender & receiver

  Two-way may use different security ⇒Two SA's required
- Defined by 3 parameters:
  - Security Parameters Index (SPI)
  - IP Destination Address
  - Security Protocol Identifier: AH or ESP
- For each SA, the database contains:
  - SPI
  - Sequence number counter and counter overflow flag
  - Anti-replay window
  - AH Information and ESP information
  - Lifetime of the SA
  - Mode: Transport or tunnel or wildcard
  - Path MTU

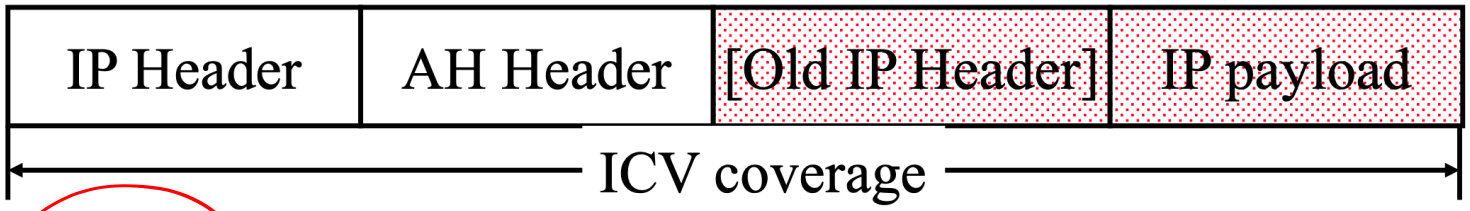
Authentication Header



- Authenticating data origins, guaranteeing data integrity, optional anti-replay services
- Next Header: TCP=6, UDP=17, IP=4, AH=51 ⇒ Designed by IPv6 fans
- Payload Length: Length of ***AH*** in 32-bit words – 2 (for IPv4) =Length of AH in 64-bit words -1 (for IPv6)
- SPI = Identifies Security association (0=Local use,1-255 reserved)
- Authentication data = Integrity Check Value



AH ICV Computation



- HMAC algorithm used for integrity GCM
- The AH ICV is computed over:
- IP header fields that are either *immutable* in transit or that are *predictable* in value upon arrival at the endpoint for the AH SA, e.g., source address (immutable), destination address with source routing (mutable but predictable)
- The AH header and explicit padding bytes (if any))
- The upper level protocol data, which is assumed to be immutable in transit

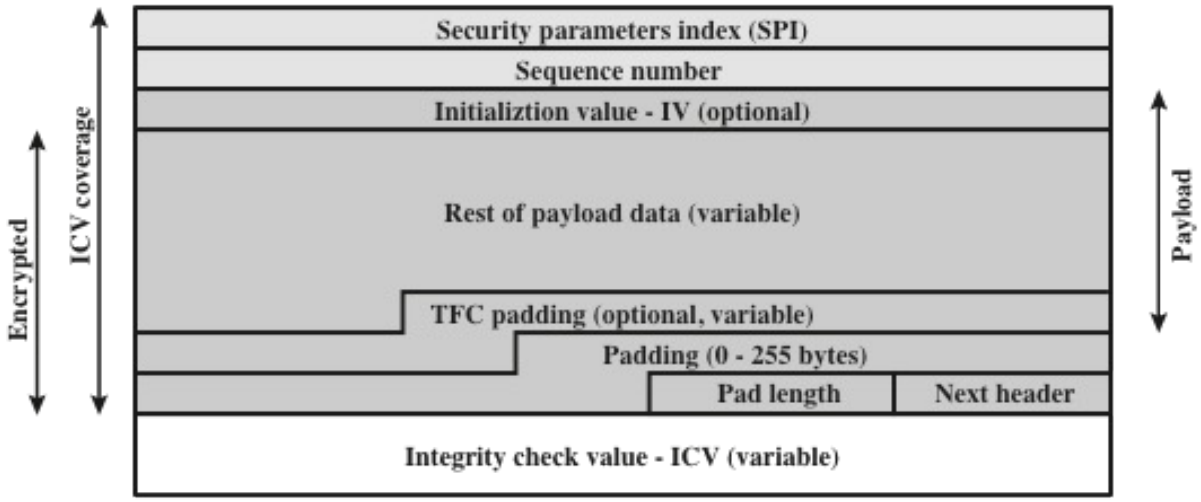
Encapsulating Security Payload (ESP)

Provides:

- Message content confidentiality,
- Data origin authentication,
- Connectionless integrity,
- Anti-replay service,
- Limited traffic flow confidentiality
- Services depend on options selected when establish Security Association (SA), net location
- Can use a variety of encryption & authentication algorithms

ESP Packet

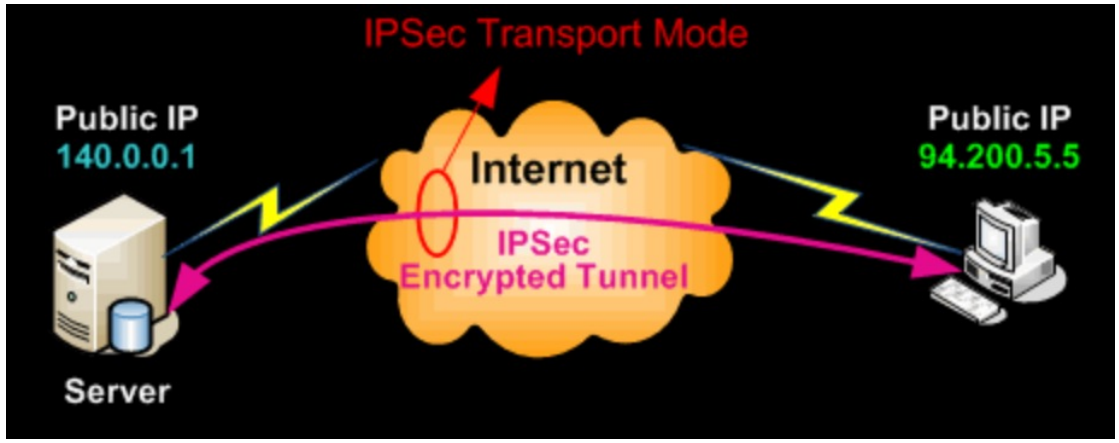
https://www.ibm.com/docs/en/zos/2.4.0?topic=ipsec-ah-esp-protocols



- Payload data: IP, TCP, UDP packet
- Padding: ensure data packet terminates on a 4 byte boundary
- Pad Length in bytes
- Next Header: Type of payload (TCP, UDP, ...)
- Authentication Data: Integrity Check Value over ESP packet

Transport Mode

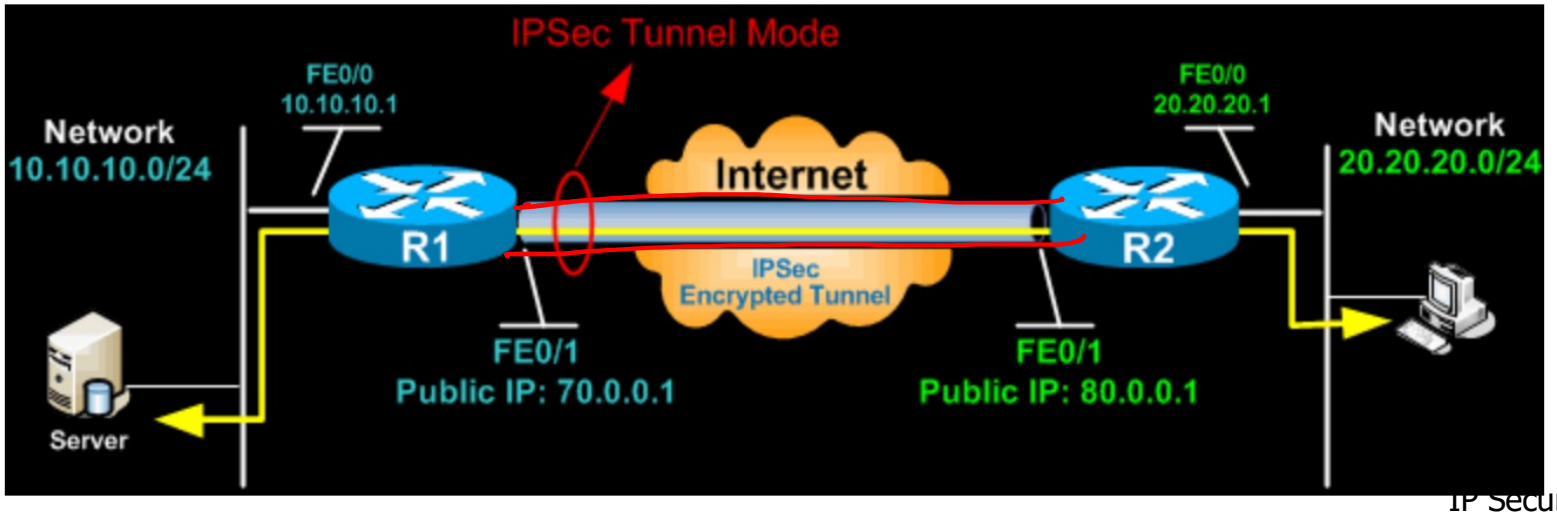
- Provides protection primarily for upper-layer protocols
- Examples include a TCP or UDP segment or an ICMP packet
- Typically used for end-to-end communication between two hosts
- Does not provide protection or encryption to the original IP header
- ESP in transport mode encrypts and optionally authenticates the IP payload but not the IP header
- AH in transport mode authenticates the IP payload and selected portions of the IP header



http://www.firewall.cx/networking-topics/protocols/870-ipsec-modes.html

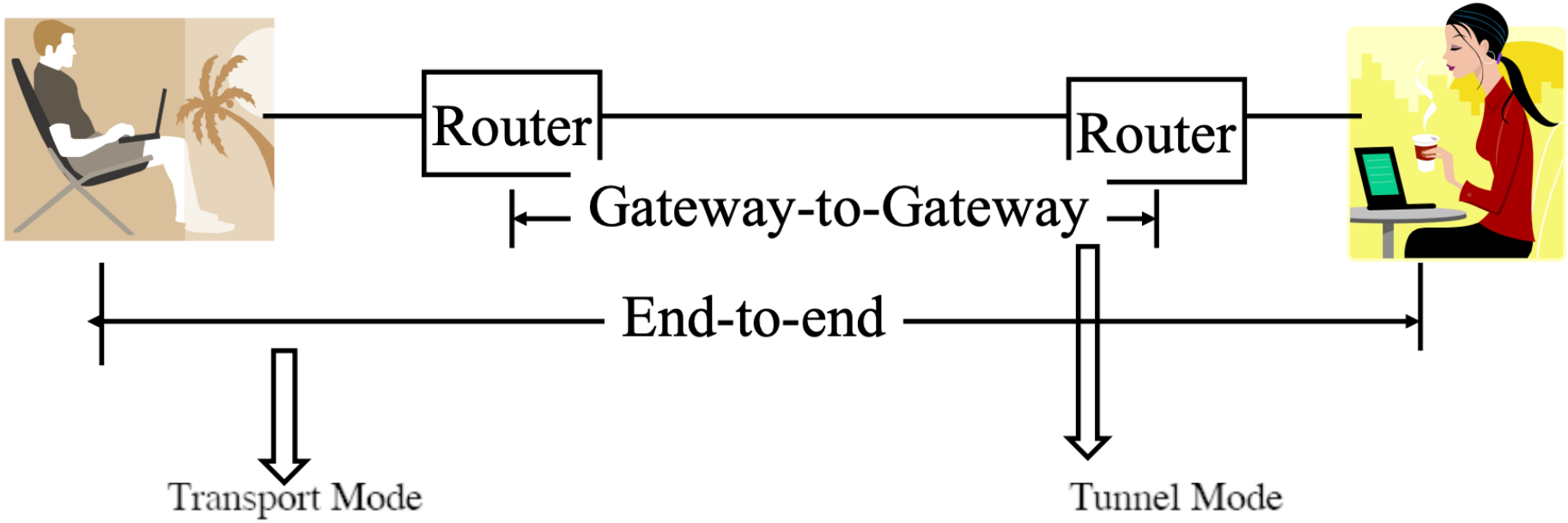
Tunnel Mode

- Provides protection to the entire IP packet
- Used when one or both ends of a security association (SA) are a security gateway
- A number of hosts on networks behind firewalls may engage in secure communications without implementing IPsec
- ESP in tunnel mode encrypts and optionally authenticates the entire inner IP packet, including the inner IP header
- AH in tunnel mode authenticates the entire inner IP packet and selected portions of the outer IP header



Tunnel vs. Transport Mode

- Gateway-to-gateway vs. end-to-end



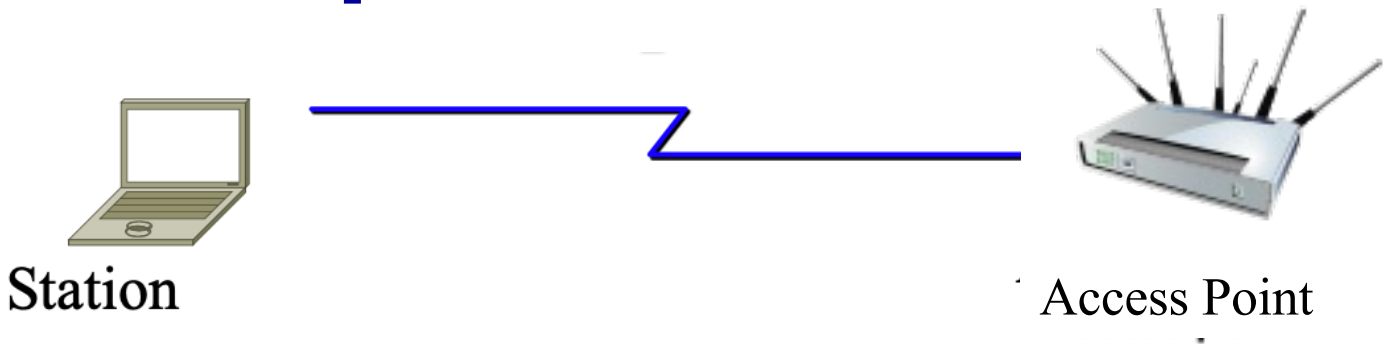
Tunnel Mode v.s. Transport Mode

	Transport Mode SA	**Tunnel Mode SA**
AH	Authenticates IP payload and selected portions of IP header and IPv6 extension headers.	Authenticates entire inner IP packet (inner header plus IP payload) plus selected portions of outer IP header and outer IPv6 extension headers.
ESP	Encrypts IP payload and any IP v6 extension headers following the ESP header.	Encrypts entire inner IP packet.
ESP with Authentication	Encrypts IP payload and any IP v6 extension headers following the ESP header. Authenticates I P payload but not IP header.	Encrypts entire inner IP packet. Authenticates inner IP packet.

Network Access Enforcement Methods

- Actions that are applied to ARs to regulate access to the enterprise network
  - **IEEE 802.1X (WiFi):** enforces authorization before a port is assigned an IP address. IEEE 802.1X makes use of the Extensible Authentication Protocol (EAP) for the authentication process.
  - **Firewall**: allow or deny network traffic between an enterprise host and an external user.
  - **DHCP Management**: DHCP enables dynamic allocation of IP addresses to hosts. A DHCP server intercepts DHCP requests and assigns IP addresses. Thus, NAC enforcement occurs at the IP layer based on subnet and IP assignment.
    - IP Spoofing
    - DHCP snooping
  - **Network Segmentation (VLANs)**: the enterprise network, consisting of an interconnected set of LANs, is segmented logically into a number of virtual LANs. The NAC system decides to which of the network's VLANs it will direct an AR.

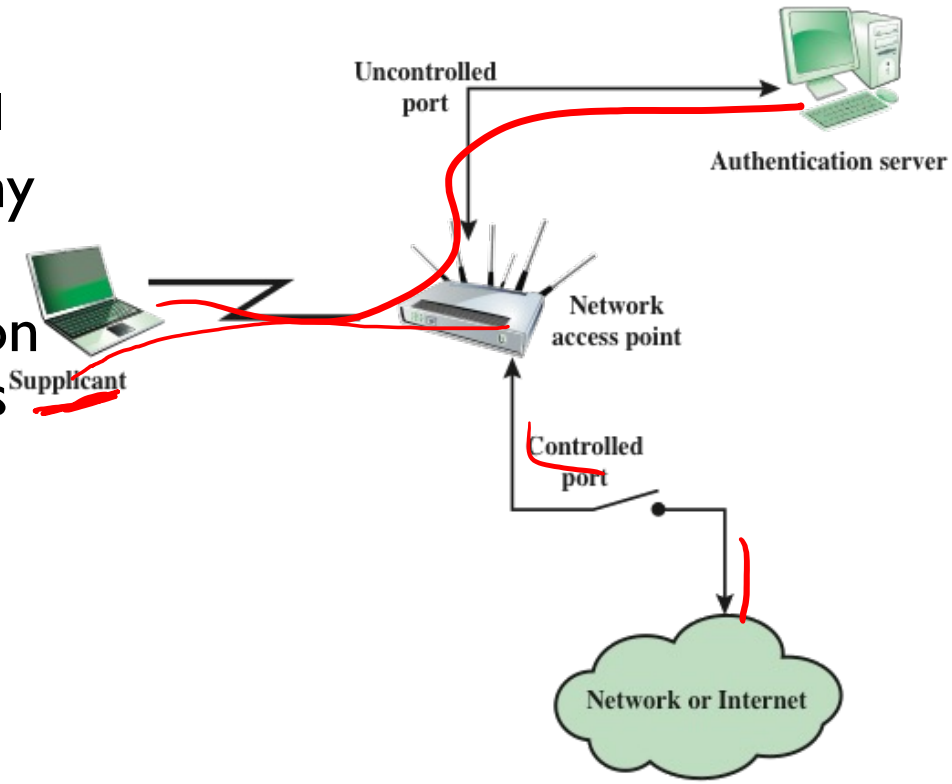
Wi-Fi Operation



- Access Points (APs) periodically broadcast a beacon with SSID (service set ID) and security level
- Subscriber stations listen to these beacons, measure signal strength and determine which AP to join
- Subscribers can also send a "Probe" to find AP's in the neighborhood
- AP authenticates the subscriber station using shared keys
- Subscriber stations and AP exchange encrypted packets
- Subscriber station send a "Disassociate" message and log off

802.1X

- Authentication framework for IEEE 802 networks
  - Supplicant (Client), Authenticator (Access point), Authentication server
  - Uncontrolled port for control channel
  - Controlled port for data channel
- User is not allowed to send any data until authenticated
- Need to upgrade only driver on NIC and firmware on switches



IEEE 802.11i Phases of Operation

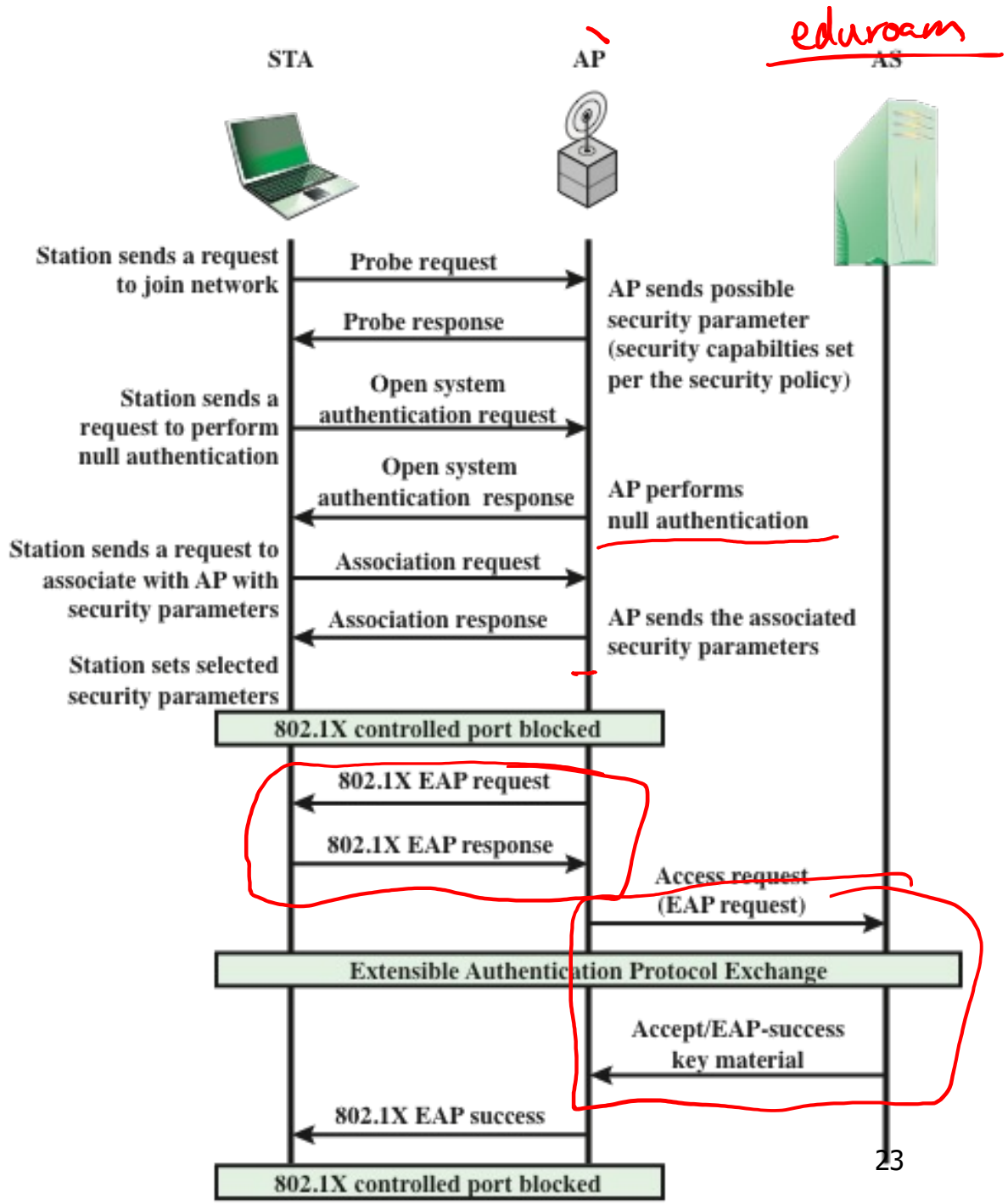
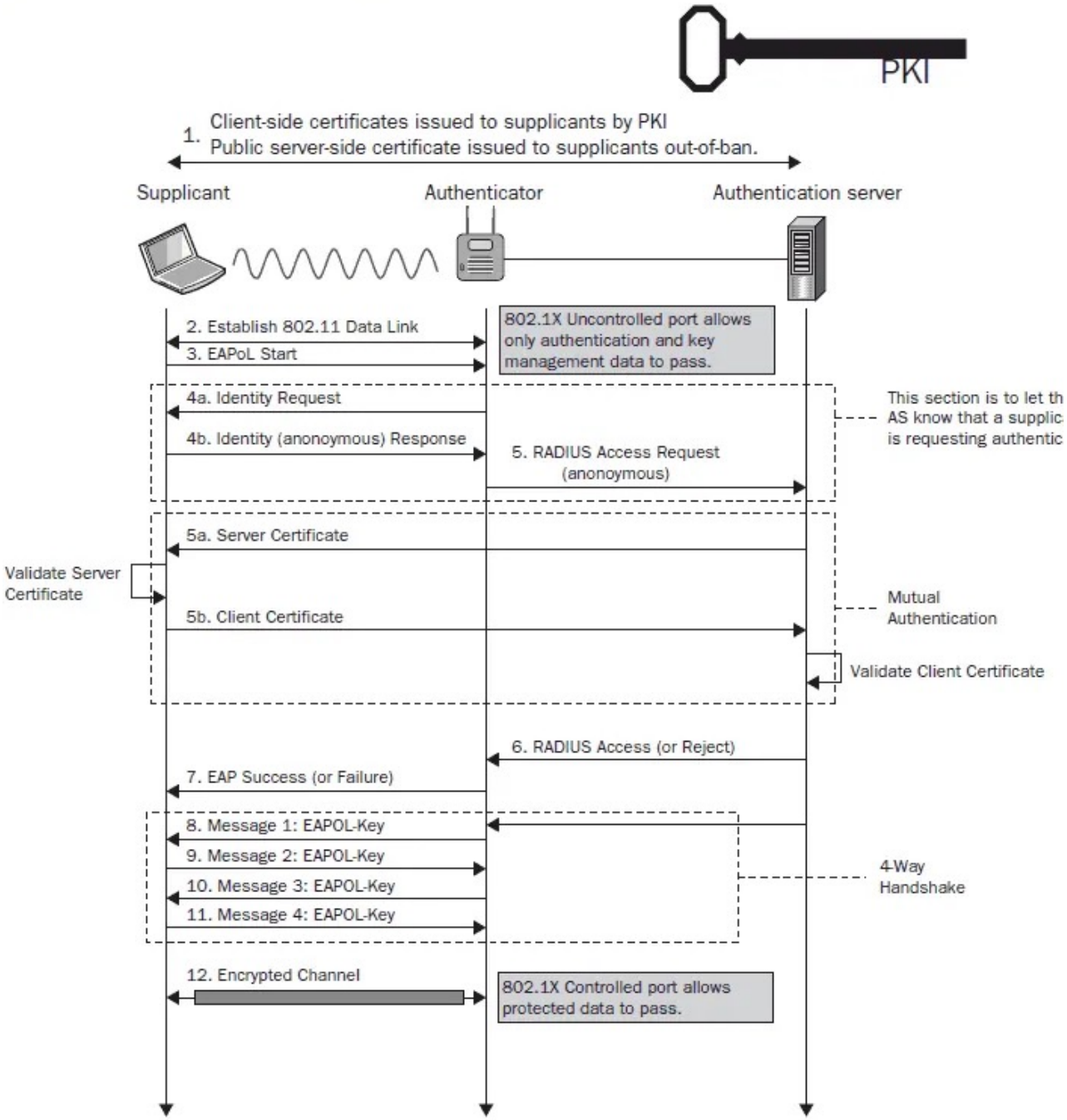


FIGURE 4.29 EAP-TLS process



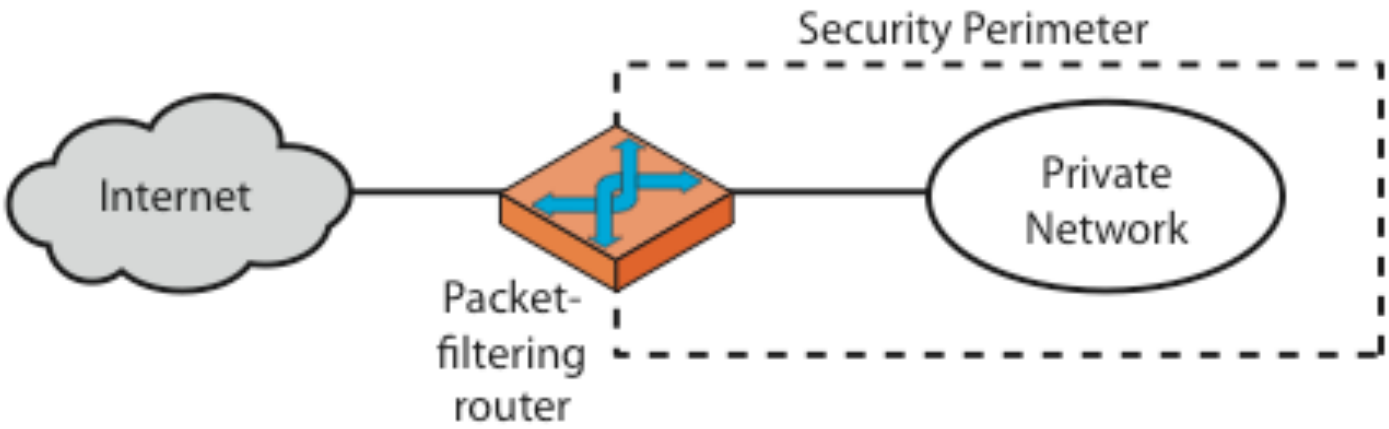
Firewall Policy

- User control:
  - § Controls access to the data based on the role of the user who is attempting to access it. Applied to users inside the firewall perimeter.
- Service control:
  - § Controls access by the type of service offered by the host. Applied on the basis of network address, protocol of connection and port numbers.
- Direction control:
  - § Determines the direction in which requests may be initiated and are allowed to flow through the firewall. It tells whether the traffic is "inbound" (From the network to firewall) or vice-versa "outbound"

Classification of Firewall

- Depending on the mode of operation, there are three types of firewalls:
  - § Packet Filter Firewall
  - § Stateful Firewall
  - § Application/Proxy Firewall

Firewalls – Packet Filters



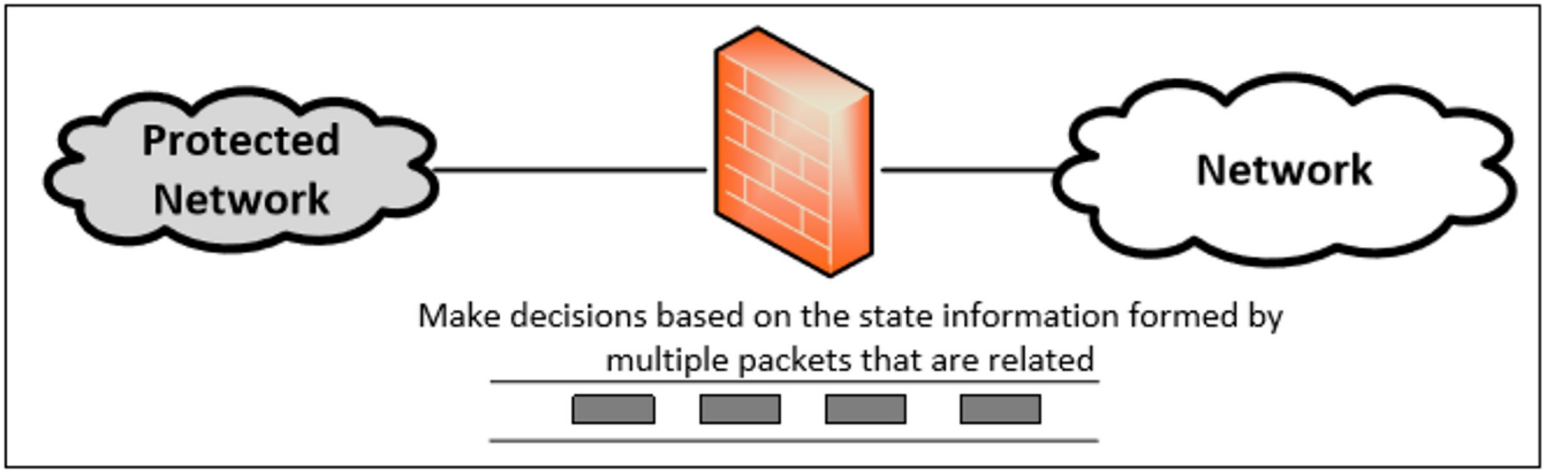
(a) Packet-filtering router

- Controls traffic based on the information in packet headers, without looking into the payload that contains application data.
- Doesn't pay attention to if the packet is a part of existing stream or traffic.
- Doesn't maintain the states about packets. Also called Stateless Firewall.

Packet Filters

- Simplest of components
- Uses network and transport layer information only
  - IP Source Address, Destination Address
  - Protocol/Next Header (TCP, UDP, ICMP, etc)
  - TCP or UDP source & destination ports
  - TCP Flags (SYN, ACK, FIN, RST, PSH, etc)
  - ICMP message type
- Examples
  - DNS uses port 53
    - No incoming port 53 packets except known trusted servers
  - Telnet uses port 23
    - Block all incoming TCP packets with port 23

Firewalls – Stateful Firewall

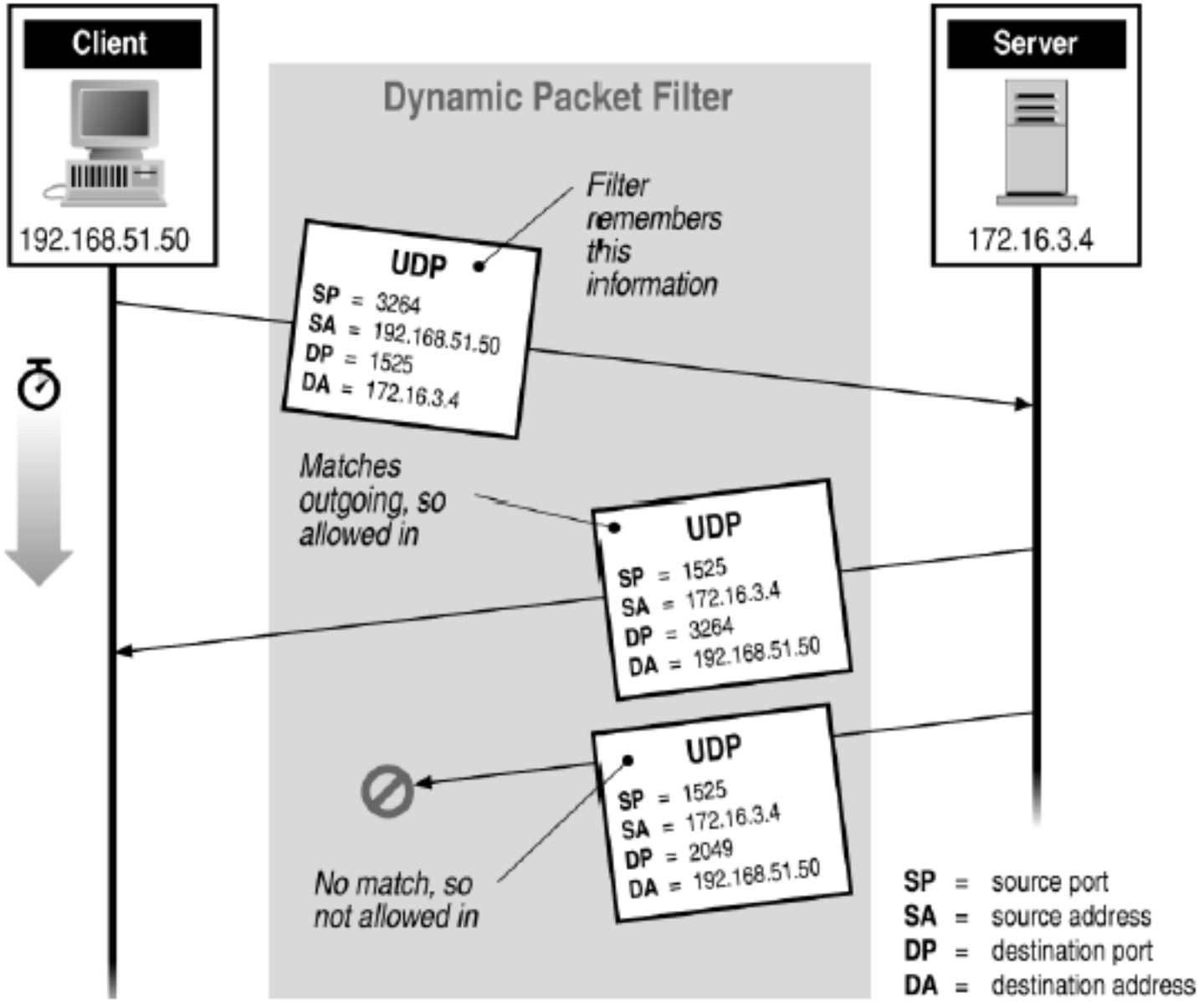


- Tracks the state of traffic by monitoring all the connection interactions until is closed.
- Connection state table is maintained to understand the context of packets.
- Example : Connections are only allowed through the ports that hold open connections.

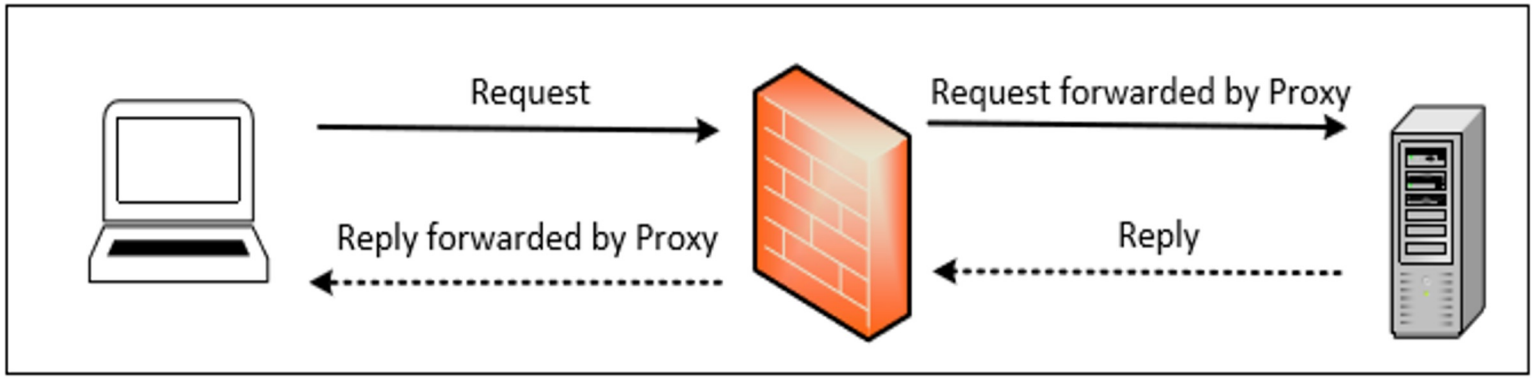
Firewalls – Stateful Packet Filters

- Traditional packet filters do not examine transport layer context
  - i.e. matching return packets with outgoing flow
- Stateful packet filters address this need
- They examine each IP packet in context
  - Keep track of client-server sessions
  - Check each packet validly belongs to one
- Hence are better able to detect bogus packets out of context

Stateful Filtering



Firewalls – Application/Proxy Firewall



- Controls input, output and access from/to an application or service.
- Acts an intermediary by impersonating the intended recipient.
- The client's connection terminates at the proxy and a separate connection is initiated from the proxy to the destination host.
- Data on the connection is analyzed up to the application layer to determine if the packet should be allowed or rejected.

Application-Level Filtering

- Has full access to protocol
  - user requests service from proxy
  - proxy validates request as legal
  - then actions request and returns result to user
- Need separate proxies for each service
  - WAF (Web Application Firewall)
  - SMTP (E-Mail Firewall)
  - DNS (Domain Name System)
  - custom services generally not supported

Application/Proxy Firewall and Web Proxy

- Proxy can also be used to evade egress filtering.
  - If a firewall conducts packet filtering based on destination address, we can evade this firewall by browsing the Internet using web proxy.
  - The destination address will be modified to the proxy server which defeats the packet filtering rules of the firewall.
- Anonymizing Proxy: One can also use proxies to hide the origin of a network request from servers. As the servers can only see the traffic after it passes through proxies, source IP will be the proxy's and actual origin is hidden.

Evading Firewalls

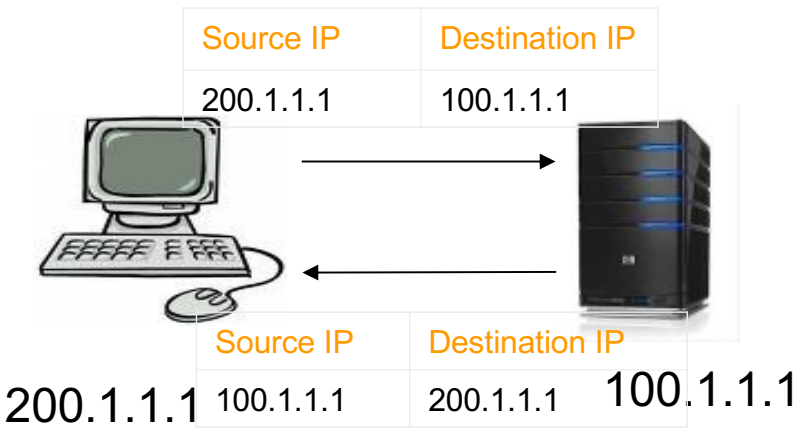
- SSH Tunneling
- Dynamic Port Forwarding
- Virtual Private Network
  - Using VPN, one can create a tunnel between a computer inside the network and another one outside. IP packets can be sent using this tunnel. Since the tunnel traffic is encrypted, firewalls are not able to see what is inside this tunnel and cannot conduct filtering. This topic is covered in VPN topic.

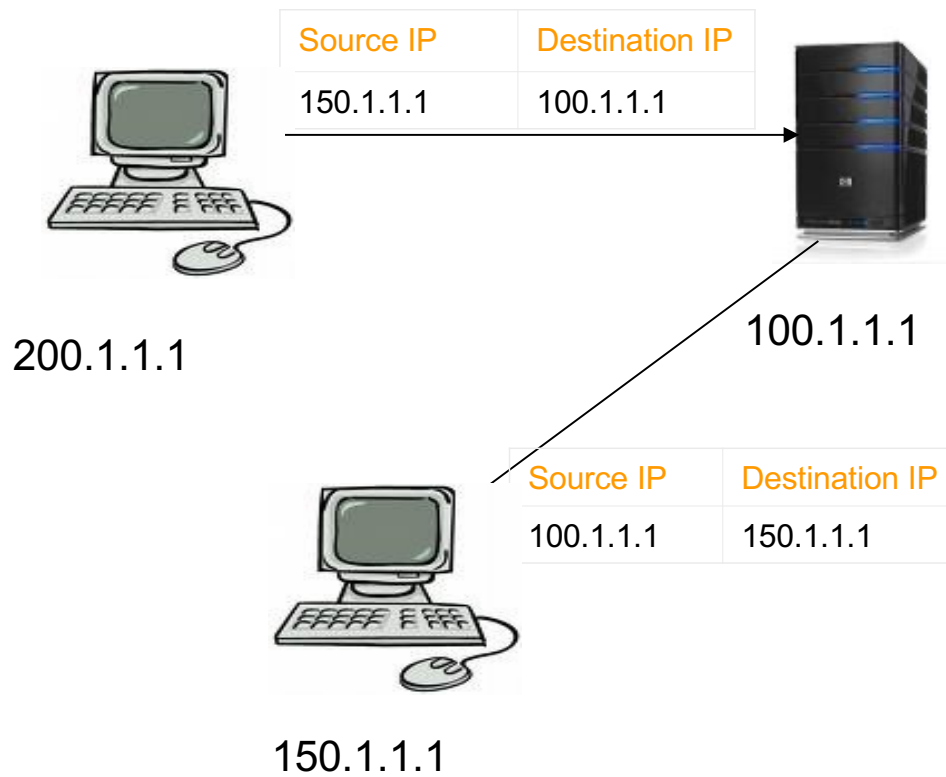
Common Network Layer Attacks

- IP Spoofing
- ICMP Echo Attack
- Smurf Attack
- Ping of Death
- Teardrop Attack
- ICMP Destination Unreachable Attack

IP Address Spoofing

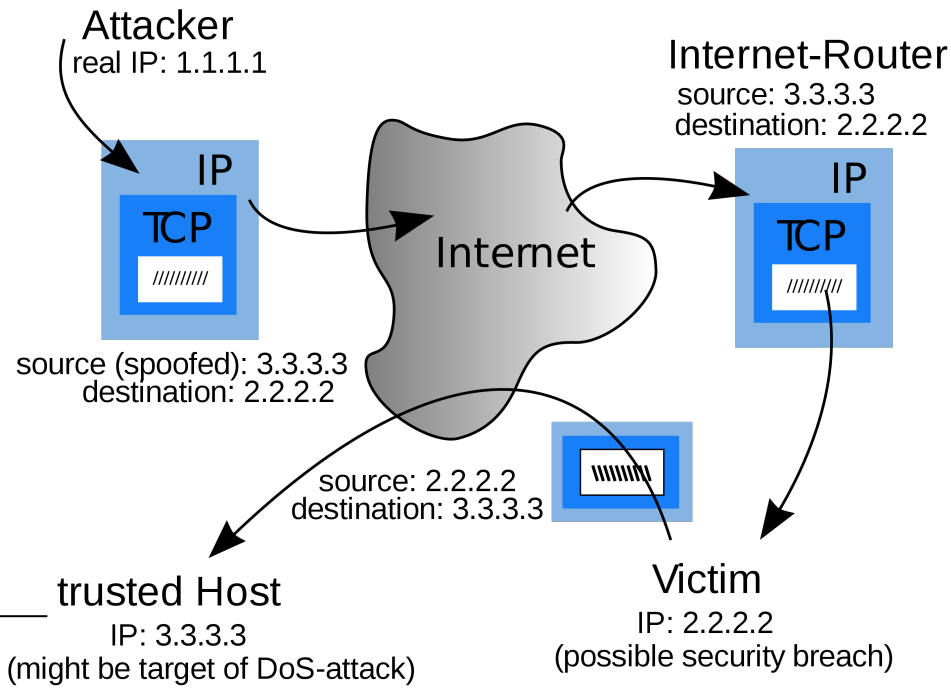
- IP spoofing is the creation of IP packets using somebody else's IP address as source address of a IP packet
- Absence of state information makes IP protocol vulnerable to spoofing
  - Peer is not authenticated

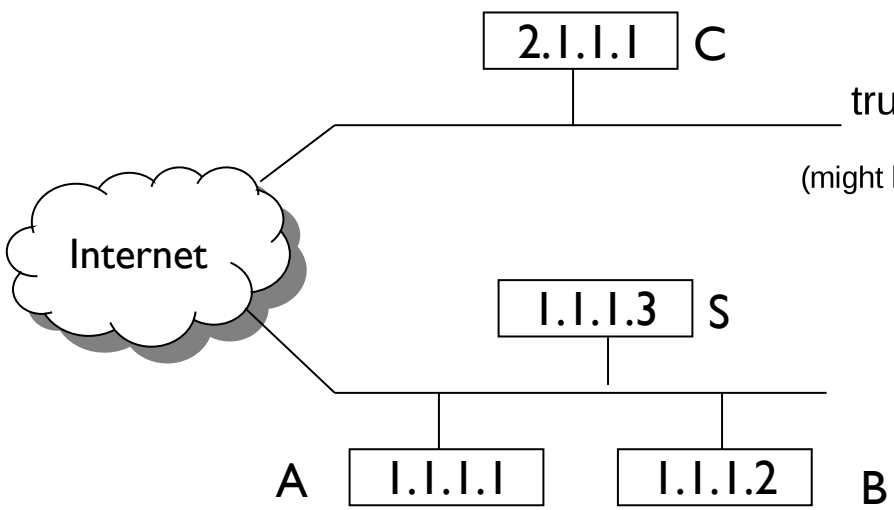




IP Spoofing Attack

- lead to
  - unauthorized access
  - data leakage
  - distributed denial-of-service (DDoS) attacks





From wiki: causing DDoS attack

Defenses Against IP Address Spoofing

- Packet filtering
  - Ingress filtering
  - Egress filtering
- Avoiding trust relationship based on IP address
- TTL Value
- IPSec
- Randomized Initial Sequence Number in TCP
- Unicast Reverse Path Forwarding

ICMP Echo Attacks

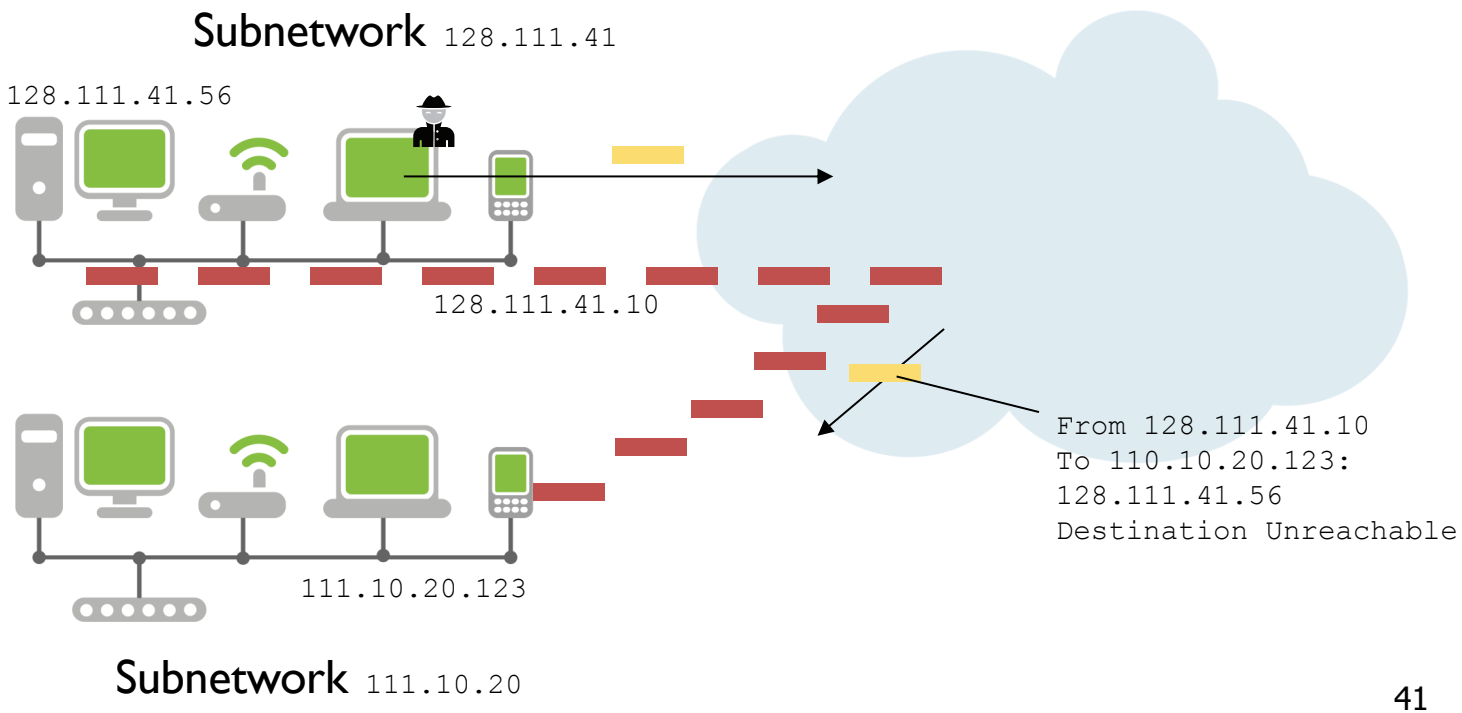
- ICMP Echo Request messages can be used to map the hosts of a network (pingscan or ipsweep)
  - ICMP echo datagrams are sent to all the hosts in a subnetwork
  - The attacker collects the replies and determines which hosts are actually alive

```
Starting nmap by Fyodor (fyodor@dhp.com,
   www.insecure.org/nmap/)
Host cisco-sales.ns.com (192.168.31.11) appears to be up.
Host sales1.ns.com (192.168.31.19) appears to be up.
Host sales4.ns.com (192.168.31.22) appears to be up.
Host sales2.ns.com (192.168.31.43) appears to be up.
Host sales3.ns.com (192.168.31.181) appears to be up.

Nmap run completed -- 256 IP addresses (5 hosts up) scanned in
   1 second
```

Destination Unreachable Attacks

- Forged destination unreachable messages can cut out nodes from the network (denial of service)



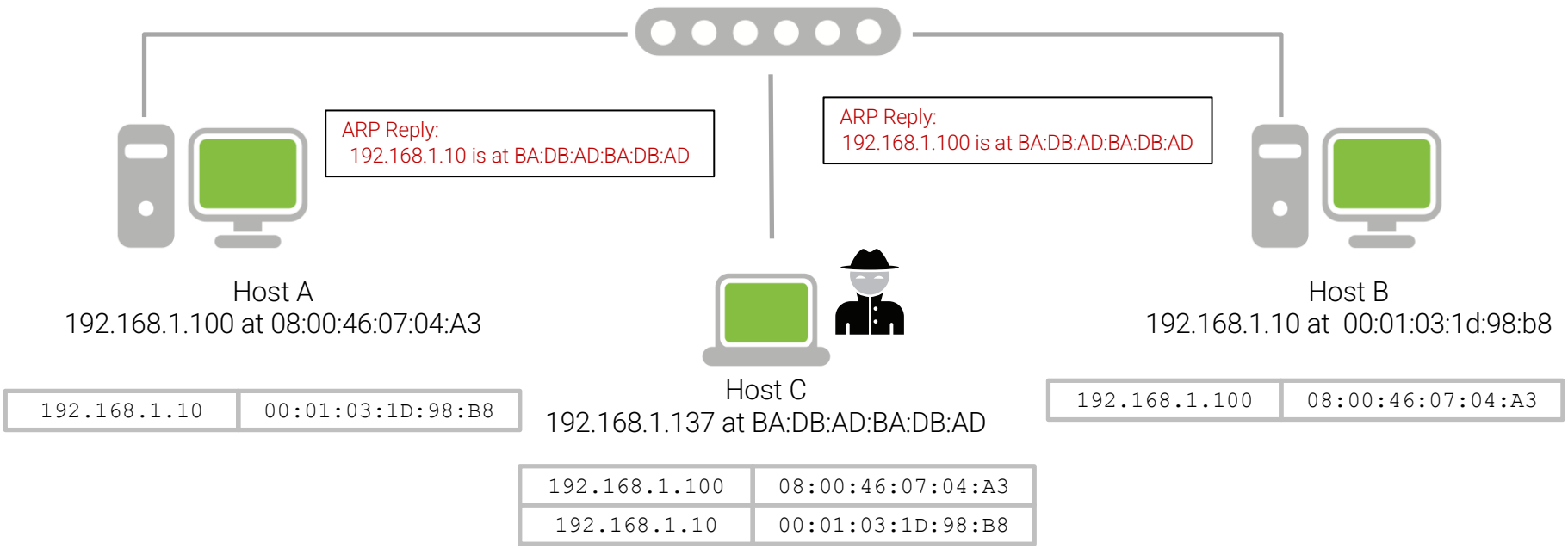
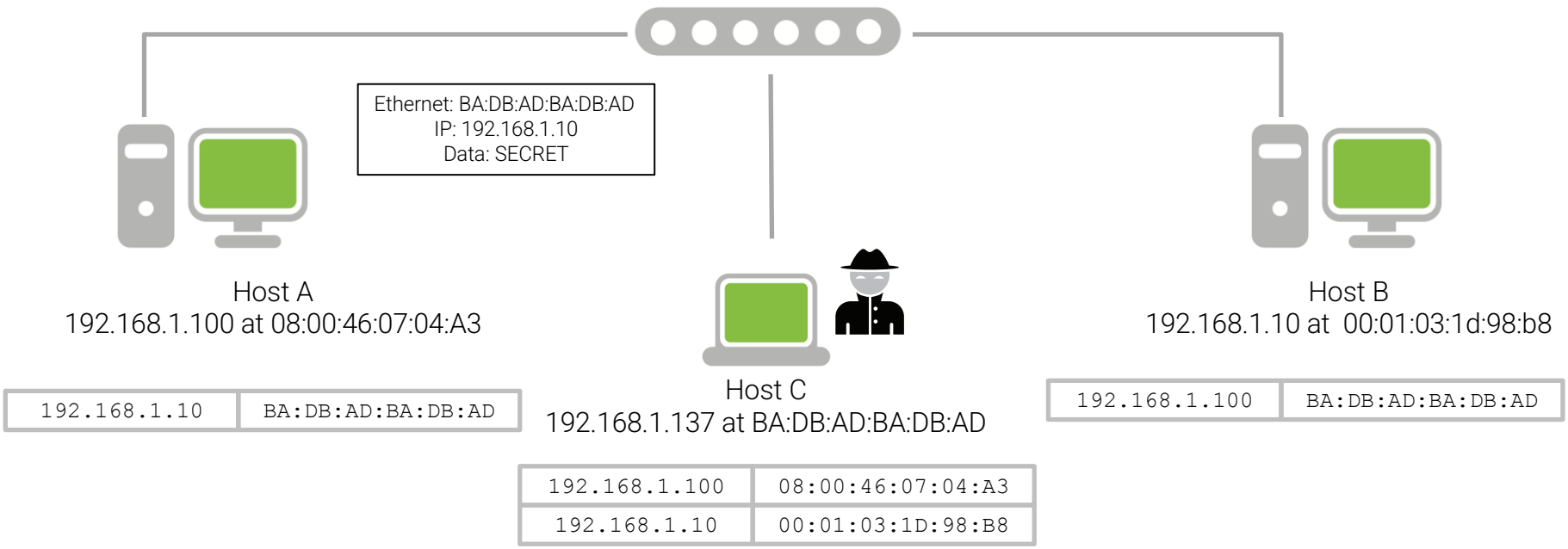
Fragmentation Attack for Evasion

- Firewalls and intrusion detection systems analyze incoming datagrams
  - using datagram header and TCP header (TCP ports, UDP ports, SYN and ACK flags)
- Some firewalls make a decision on the first fragment and let the other fragments through by keeping track of the datagram ID
  - The first fragment of a TCP-over-IP may contain only 8 bytes (source and destination ports for both UDP and TCP)
    - Setup flags (SYN/ACK) can be "postponed" so that incoming SYNs can go through

ARP Spoofing

- Goal: sniff all traffic between two hosts in a switched environment
- The attack leverages the stateless nature of the ARP protocol
  - Replies without a request will be accepted
- The attacker host sends spoofed ARP messages to the two victim hosts, poisoning their cache
- The victim host sends their IP packets to the attacker host
- The attacker host acts has a router

ARP Spoofing



Man-In-The-Middle (MITM)